

Post-Exploitation

CHAPTER 9

9.01 - Post-Exploitation Techniques

Episode title: **Post-Exploitation Techniques**

Objective: **3.7 Given a scenario, perform post-exploitation techniques**

POST-EXPLOITATION TECHNIQUES

- **What to do once you're in**

- Make it easier next time

- **Lateral movement**

- Remote Procedure Call /
Distributed Component
Object Model (RPC/DCOM)
 - PsExec – Utility that supports
executing processes on other
systems (i.e. telnet)
 - Windows Management
Instrumentation (WMI) - Managing
devices and applications from
remote computers
 - Scheduled tasks

LATERAL MOVEMENT

- **PS remoting/WinRM**
 - PowerShell remoting/Windows Remote Management
- **Server Message Block (SMB)**
 - Protocol for exposing shares to remote computers (Linux, etc. too)
- **Remote Desktop Protocol (RDP)**
 - Ability to access a desktop from a remote computer
- **Apple Remote Desktop**
 - Apple's RDP

LATERAL MOVEMENT

- **Virtual Network Computing (VNC)**
- **X-server forwarding**
 - X-windows access to Linux desktop
- **Telnet**
 - Unsecure remote access (everything in cleartext)
- **Secure Shell (SSH)**
 - More secure remote access to shell
- **RSH/Rlogin (Remote Shell / Remote login)**
 - Legacy secure remote access

9.02 - More Post-Exploitation Technique

Episode title: **More Post-Exploitation Technique**

Objective: **Add: 5.1.10, 5.1.11, 5.1.12, 5.2.1, 5.2.2, 5.2.4.10, 5.2.4.11, 5.2.4.12, 5.2.4.13**

ROOTKITS

- **Software to hide presence**

- User or kernel level
- Hooks into system processes
- Hard to detect/remove

BROWSER EXTENSIONS

- **Compromised or malicious**

- Intercept web traffic
- Capture logon credentials
- Sync across browsers

TAMPERING WITH SECURITY CONTROLS

- **Disabling security controls**

- Interfering with defenses
- Techniques:
 - Group policy tweaks
- Injecting into AV processes

LATERAL MOVEMENT WITH PIVOTING

- **Useful in segmented environments**
- **Tools:**
 - SSH tunneling
 - Metasploit
 - Proxy chain

RELAY CREATION

- **Process of capturing authentication traffic**
 - Authenticate/exploit systems
 - Tools:
 - NTLM relay
 - Responder

LEGACY PRINTING PROTOCOLS

- **Line Printer Daemon (LPD)**

- Unix/Linux environments
- Execute commands remotely

- **Jetdirect**

- HP network printers
- Alter printer behavior

RPC AND DCOM

- **Invoke actions remotely**

- Tools:
 - PS Exec
 - WMI

PROCESS IDs (PIDs)

- **Unique process numbers**

- Inject code
- Steal tokens
- Tools:
 - Memicats
 - PowerShell

9.03 - Post-Exploitation Tools

Episode **Post-Exploitation Tools**
title:

Objective: **3.7 Given a scenario, perform post-exploitation techniques**

POST-EXPLOITATION TOOLS

- **Empire (4.2.12.5)**
 - <https://alpinesecurity.com/blog/empire-a-powershell-post-exploitation-tool/>
- **Mimikatz (4.2.2.7)**
 - <https://github.com/ParrotSec/mimikatz>
- **Bloodhound**
 - <https://bloodhound.readthedocs.io/en/latest/>

9.04 - Network Segmentation Testing

Episode title: **Network Segmentation Testing**

Objective: **3.7 Given a scenario, perform post-exploitation techniques**

NETWORK SEGMENTATION TESTING

- **Tests to confirm that network segments work as designed**
 - Only approved traffic flows between segments
 - No gaps exist that attackers can exploit
- **Involves scanning and carrying out a vulnerability assessment on each network segment**

NETWORK SEGMENTATION TESTING

- **Strategy**
 - ICMP scan
 - TCP scan
 - UDP scan

9.05 - Persistence and Stealth

Episode title: **Persistence and Stealth**

Objective: **3.7 Given a scenario, perform post-exploitation techniques**

PERSISTENCE

- **Scheduled jobs**
 - Cron or Task Manager
- **Scheduled task**
 - Same as above
- **Daemons**
 - Background processes or services

PERSISTENCE

- **Back doors**
 - Bypass standard security controls
- **Trojan**
 - Malware that looks like it does something useful
- **New user creation**
 - Makes later logins easier

STEALTH

- Clean up files, including tools installed
- Hiding files that you need to leave
- Sanitize log files (remove entries or entire logs)
- Remove any traces of activity while accessing the environment

9.06 - Detection Avoidance Techniques

Episode title: **Detection Avoidance Techniques**

Objective: **3.7 Given a scenario, perform post-exploitation techniques**

DETECTION AVOIDANCE

- **Living-off-the-land techniques – fileless malware**
 - PsExec – Lightweight telnet replacement from Microsoft
 - Supports launching remote interactive command prompts
 - Windows Management Instrumentation (WMI)
 - Extensions that provide OS interface capability
 - PowerShell (PS) remoting and Windows Remote Management (WinRM)

DETECTION AVOIDANCE

- **Data exfiltration**
- **Covering your tracks**
- **Steganography**
- **Establishing a covert channel**

9.07

Episode title: **More Detection
Avoidance Techniques**

Objective: **5.3.3, 5.3.4, 5.3.5, 5.3.6, 5.3.7, 5.3.8**

E-MAIL EXFILTRATION

- Common outbound protocol
- Embed data in attachments
- Encrypted in transit

CLOUD ENVIRONMENTS

- Cross account resources
- Shared S3 buckets
- Bypass detection tools

CLOUD STORAGE SERVICES

- **Upload to trusted services**

- Dropbox
- OneDrive
- Amazon S3

- **Traffic goes unnoticed**

ALTERNATE DATA STREMS (ADS)

- NTFS File System Feature
- Hide data in files
- Secondary stream hidden

TEXT STORAGE SITES

- **Post data:**
 - Pastebin
 - Ghostbin
- **Publish credentials or tokens**
- **Automate with scripts**

VIRTUAL DRIVE MOUNTING

- Mount WebDAV share
- OneDrive sync folder
- Blends with normal activity